BioSpecInfo

Security, Privacy & Compliance — BioSpecInfo

Samuele Pio Provenzano

Versione **bsi-v240** · commit `6794af6`

Generato il 2026-11-05

Documento generato automaticamente dal sorgente Markdown versionato nel repository. La versione e il commit stampati in ogni piè di pagina identificano esattamente lo stato del software descritto.

Security, Privacy & Compliance — BioSpecInfo

Campo	Valore
Software	BioSpecInfo
Autore	Samuele Pio Provenzano
Modello	Client-side / Local-First PWA

1. Privacy & protezione dei dati (GDPR)

1.1 Local-First per progettazione

- **Nessun account, nessun login, nessun tracciamento pubblicitario.**
- Tutti i dati dell'utente (molecole disegnate, preferenze, cronologia dei quiz,

progressi di studio) sono conservati **esclusivamente in locale** sul dispositivo (`localStorage` / IndexedDB / `sql.js`), senza trasmissione a server dell'autore.

- **Non esiste un backend applicativo** che raccolga o elabori dati personali.

1.2 Trattamento dei dati e allineamento GDPR

- **Minimizzazione dei dati:** l'app non richiede dati personali per funzionare.
- **Assenza di trasferimento a terzi dell'autore:** i dati non lasciano il

dispositivo per infrastrutture controllate dall'autore.

- **Chiamate esterne opzionali e trasparenti:** solo su azione dell'utente

(ricerca di una molecola, apertura di un modello 3D) l'app interpella API pubbliche di terzi (PubChem, NASA/ESA, database spettrali). Tali richieste contengono **solo l'identificativo chimico** (es. SMILES/nome) e **nessun dato personale**. L'uso di questi servizi è soggetto alle rispettive privacy policy.

- **Voce di qualità di Spectra (dalla v239, `bsi-spectra-voce.js`):** se

l'utente ha salvato nell'app una chiave OpenAI, il **testo che Spectra pronuncia** (fino a 3 800 caratteri per volta: risposte della console, passi della lezione guidata, testi di Spectra Studio) viene inviato direttamente dal browser a `api.openai.com/v1/audio/speech` (`gpt-4o-mini-tts` , voce «onyx»; `tts-1` come ripiego), con la chiave dell'utente. Succede **anche quando la chat usa un altro fornitore**, e la richiesta non passa dal proxy. Il testo può contenere ciò che l'utente ha chiesto e ciò che Spectra ricorda di lui. L'audio ricevuto resta solo in memoria per la sessione. Senza chiave OpenAI questo flusso non esiste: si usa la sintesi vocale del browser. Per evitarlo si spegne la voce (🔇) nella console, nella lezione guidata e in Spectra Studio, dove la scelta resta ricordata (`bsi-spectra-studio-voce`); oppure non si salva una chiave OpenAI.

- **«🧠 Spiega» e lo schermo (`bsi-spectra-spiega.js`, dalla v240):** con

la casella **«📺 Includi lo schermo»** attiva (lo è da sola quando dietro la finestra c'è una sezione aperta), insieme alla domanda vanno al fornitore di IA configurato, con la sua chiave, **il testo dello schermo** (sezione, scheda, valori dei comandi, tabelle e testo visibili) e **un'immagine dei grafici e delle scene 3D visibili**, come un allegato della chat; l'immagine va solo nel primo turno. Con la casella spenta va solo la domanda. **La spunta tolta dall'utente si rispetta**: anche quando Spectra apre una sezione nominata nella domanda («spiegami le titolazioni») o scelta dal catalogo «🗂️ Tutte le sezioni nell'ologramma», la sezione si apre dietro la finestra e si mostra nell'ologramma, ma la casella resta spenta e al modello va solo la domanda, senza testo né immagine dello schermo. Solo le domande rapide sullo schermo («📈 Spiegami questo grafico»…) rimettono la spunta, perché sono una scelta esplicita. Senza chiave non esce niente dal dispositivo. La conversazione resta in memoria per la sessione e non si salva.

- **Corpo di Spectra Studio (`spectra-studio.html`):** un file `.glb` caricato

con il pulsante «🧍 Corpo» resta solo nell'IndexedDB del browser (`bsi-spectra-modelli`) e non viene inviato a nessun server. Si cancella con «Cancella dati → Progressi del resto dell'app».

- **Diritto all'oblio locale:** l'utente può cancellare i dati svuotando lo

storage del sito dal browser.

> **Nota.** Questo allineamento descrive le proprietà di design local-first che favoriscono la conformità GDPR. Non costituisce una certificazione legale; per contesti regolamentati si raccomanda una valutazione DPIA dedicata.

---

2. Sicurezza applicativa (OWASP)

2.1 Superficie di attacco

Essendo un'applicazione **statica senza backend**, sono assenti per costruzione intere classi di vulnerabilità server-side (SQL injection su DB server, RCE lato server, autenticazione/sessione server, IDOR su API proprietarie).

2.2 Sanitizzazione degli input

- Il parsing di stringhe **SMILES / SMARTS** e di file molecolari è delegato a

RDKit MinimalLib (WASM), che valida le strutture e rifiuta input malformati restituendo molecole non valide anziché eseguirli.

- Le stringhe provenienti da input o da API esterne, quando inserite nel DOM,

vanno trattate come non fidate. Il valore testuale (nomi, notazioni) è mostrato come contenuto testuale/`textContent` o con escaping dei caratteri `& < >`.

2.3 Robustezza del runtime

- **Guardia su `localStorage`:** ogni accesso allo storage è protetto da

`try/catch` con fallback in memoria, per evitare che la modalità incognito o lo storage bloccato interrompa l'esecuzione (regressione storica risolta).

- **Degradazione controllata:** i pannelli non restano mai vuoti in silenzio; gli

errori mostrano un messaggio e, dove applicabile, un pulsante "Riprova".

- **Isolamento delle sotto-app** in `iframe`.

2.4 Content Security Policy (raccomandazione di deploy)

Poiché l'app è pubblicabile su hosting statico, si raccomanda di servirla con header di sicurezza a livello di hosting/CDN:

- `Content-Security-Policy` restrittiva (script/style self + WASM), `frame-ancestors`,

`X-Content-Type-Options: nosniff`, `Referrer-Policy: no-referrer`.

- `Cross-Origin-Opener-Policy` / `Cross-Origin-Embedder-Policy` se in futuro si

abiliteranno `SharedArrayBuffer` e i Web Worker paralleli (roadmap HPC).

2.5 Controlli sul lato pagina: deterrenti, non serrature

Su hosting statico ogni controllo fatto nella pagina è aggirabile da chi ha il dispositivo o legge il sorgente. Due funzioni lo dichiarano:

- **File Manager** (`file_manager.html`): la password si confronta come

impronta SHA-256; è un deterrente contro chi passa, non una protezione per documenti riservati (`08-Traceability-Matrix.md`, SEC-03).

- **Riconoscimento del creatore di Spectra** (`bsi-spectra-creatore.js`, dalla versione

`bsi-v238`): a «sono il tuo creatore» Spectra chiede la stessa frase segreta del File Manager, scritta in un campo di tipo password e confrontata come impronta SHA-256. La frase non compare nel codice, non viene conservata e non entra nel dialogo, nella memoria, nella voce né nelle richieste al modello; dopo tre tentativi sbagliati si aspetta un minuto. Nel `localStorage` resta solo il segno `bsi-spectra-creatore-v1`, cancellabile da «Cancella dati → Memoria persistente». **Non è un controllo d'accesso**: l'impronta è nel codice, il segno può essere scritto a mano da chi ha il dispositivo, e un'impronta senza sale di una frase debole si può cercare per tentativi fuori dall'app. Non protegge dati: dice a Spectra con chi parla (`08-Traceability-Matrix.md`, SEC-08; `09-Release-Conformance-Statement.md`, D-13).

---

3. Integrità e riproducibilità (allineamento GAMP 5)

Per l'uso in contesti farmaceutici/regolamentati, l'architettura è **compatibile** con i principi GAMP 5:

- **Determinismo:** i calcoli chemioinformatici (RDKit) sono deterministici e

riproducibili a parità di input.

- **Tracciabilità delle versioni:** versionamento del codice su Git, cache del Service Worker versionata, changelog.
- **Trasparenza dei metodi:** i predittori euristici sono documentati con le loro fonti e i loro limiti (vedi *Validation Report*).

> Anche qui: si tratta di **allineamento ai principi**, non di una qualifica formale (IQ/OQ/PQ), che richiederebbe un processo di validazione dedicato presso l'organizzazione utilizzatrice.

---

4. Riepilogo

Aspetto	Stato
Dati personali trasmessi a server dell'autore	**Nessuno**
Testo pronunciato da Spectra inviato a OpenAI per la voce	**Solo con una chiave OpenAI salvata** (§1.2)
Backend / database server	**Assente**
Validazione input molecolari	RDKit WASM
Escaping output nel DOM	Sì (contenuto non fidato)
Guardia storage / degradazione errori	Sì
CSP / header di sicurezza	Raccomandati a livello di hosting
Funzionamento offline	Sì (Service Worker)